IT Security and Acceptable Use Policy

Document ID: NL-IT-001 | Version: 4.2 | Effective: 15 May 2026 | Owner: IT Security Team

1. Scope

This policy applies to all employees, contractors, and interns who use Nimbus Labs systems, data, or devices. Violations can lead to disciplinary action up to termination. Security questions go to security@nimbuslabs.example.

2. Accounts and Passwords

- Multi-factor authentication (MFA) is mandatory on all company accounts, including email, Slack, GitHub, and AWS.
- Passwords must be at least 14 characters long. Passwords are not forced to change on a schedule, but must be changed immediately if a compromise is suspected.
- Use the company-approved password manager. Never share passwords or write them down.
- Accounts are locked for 15 minutes after 5 failed login attempts.

3. Devices

- Only company-managed laptops may be used for work, with full-disk encryption and automatic screen lock after 5 minutes of inactivity.
- Personal phones may be used for email and Slack only, after enrolment in the company's mobile device management (MDM) tool.
- USB storage devices are blocked by default. Exceptions need written approval from IT Security.
- Software is installed only from IT Self Service. Unapproved software must be requested via a Jira ticket in the IT project.
- A lost or stolen device must be reported to security@nimbuslabs.example within 2 hours of discovery.

4. Data Classification

Level	Examples	Handling rules
Public	Marketing pages, published blog posts	No restrictions.
Internal	Internal wiki, org charts, meeting notes	Share only inside the company.
Confidential	Customer lists, contracts, source code, financial reports	Store only in approved company systems. No personal cloud storage. Encrypt when sent outside the company.
Restricted	Customer personal data, passwords, API keys, payroll data	Access on need-to-know basis, logged, and never copied to laptops or chat tools.

5. Email, Phishing, and Acceptable Use

- Report suspicious emails using the Report Phishing button in the email client. Do not click links or open attachments from unknown senders.

- Company systems must not be used for illegal activity, harassment, cryptocurrency mining, or accessing adult content.
- Limited personal use of the internet is allowed if it does not affect work or security.
- AI tools: only company-approved AI assistants may be used. Never paste Confidential or Restricted data into public AI tools.

6. Security Incident Response

Any suspected incident must be reported immediately in the #security-incidents Slack channel or by emailing security@nimbuslabs.example. Incidents are rated by severity:

Severity	Description	Initial response	Update frequency
SEV1	Confirmed data breach or full outage of customer systems	15 minutes	Every 30 minutes
SEV2	Suspected breach or major service degradation	1 hour	Every 2 hours
SEV3	Limited impact, single user or system	4 hours	Daily
SEV4	Policy question or minor issue	2 business days	On resolution

Customer data breaches must be reported to the affected customers within 72 hours of confirmation.

7. Offboarding

All system access is revoked within 1 hour after the end of the employee's last working day. Company devices must be returned within 3 working days. Source code or documents must never be copied to personal accounts before leaving.